COMPREHENSIVE APPLICATION & CLOUD INFRASTRUCTURE SECURITY AUDIT

Cambodia Flavors & Tourism (v2.7.0 • Build 1508)

របាយការណ៍ត្រួតពិនិត្យសុវត្ថិភាពប្រព័ន្ធទាំងមូល — រសជាតិ និងទេសចរណ៍កម្ពុជា

AUDIT DATE	PACKAGE / APP ID	CLOUD BACKEND	AUDIT METHODOLOGY
2026-11-09	com.khmerfood.tourism	Supabase (PostgreSQL + Edge Deno)	Full Source Code + Live Config Verification

OVERALL SECURITY STATUS: FAIL (Score: 48 / 100 — Mandatory Remediation Required)

OVERALL: FAIL

Executive Summary: The application implements verified server-side controls for **Admin authentication** (PBKDF2-SHA256 + HMAC-SHA256 tokens), **VIP anti-forgery** (PostgreSQL trigger `kft_vip_grant_guard` + ABA receipt replay ledger `kft_used_aba_transactions`), **SQL injection & XSS prevention**, and **in-database backup snapshots**. However, the overall security status is graded **FAIL** due to three critical foundational risks verified in the source code and live database configuration: (1) **Public `anon` Read/Write RLS Policy on `public.kft_app_kv_store`** exposing user PII, password hashes, and transaction records without authentication; (2) **Client-side user authentication & `x-kft-prev-pw-hash` password-reset bypass**; and (3) **Android release signing keystore (`khmerfood-upload-key.jks`) and fallback password committed to version control**.

1. Executive Security Scorecard (All 9 Required Audit Domains)

#	Security Audit Domain	Status	Score	Verified Evidence Summary
1	**Anti-Hacking & Unauthorized Access Protection**	FAIL	**35/100**	Edge rate limiters & DB triggers active, but `kft_app_kv_store` has permissive `USING (true)` RLS for `anon` ; client attestation headers (`x-kft-app-sig`) can be spoofed; upload keystore is in repo.
2	**Login, Authentication, Passwords & Account Security**	FAIL	**30/100**	PBKDF2-HMAC-SHA256 (100k iterations) is used, but end-user login is verified client-side; `passwordHash` is publicly readable and can be passed back in `x-kft-prev-pw-hash` to overwrite passwords.
3	**Database, API & Server Security**	FAIL	**45/100**	8 internal tables & Gemini/Maps secrets are properly locked in Edge Functions, and `food-media` blocks anon overwrite/delete, but `kft_app_kv_store` mixes public catalog and private user data under public RLS.
4	**VIP Membership & Payment Protection**	WARNING	**75/100**	`kft_vip_grant_guard` strips forged VIP tiers/dates; `kft_used_aba_transactions` prevents ABA Trx ID & image hash replay. Warning: `kft_cloud_transactions_v1` & `kft_cloud_payment_proofs_v1` in KV store are readable by `anon` .
5	**Personal Data & Privacy Protection**	FAIL	**30/100**	Has AI consent dialog (`aiConsent.ts`), self-service account deletion (`PrivacyPolicyModal.tsx`), and `allowBackup=false` , but user PII (emails, phones, Google IDs) is readable without login via `kft_app_kv_store` and present in repo backup JSONs.
6	**Malware, SQL Injection, Data Theft & Cyberattack Prevention**	WARNING	**65/100**	Zero SQLi or XSS vectors (0 `dangerouslySetInnerHTML` / `eval`); magic-byte image

#	Security Audit Domain	Status	Score	Verified Evidence Summary
				validation & HTTPS enforced. Warning: bulk DB scraping open on `kft_app_kv_store`, empty TLS `<pin-set>`, and missing Web CSP/HSTS headers.
7	**Admin Access Control & Permission Management**	**WARNING**	**72/100**	2-step server-side PIN + Password verification in `admin-auth` with HMAC-SHA256 tokens and DB trigger enforcement (`kft_admin_keys_guard`). Warning: global lockout counter (200/day) allows DoS against admin; 7-day token TTL has no revocation list.
8	**Backup, Recovery & Data Protection**	**WARNING**	**70/100**	Automated Postgres history table (`kft_app_kv_history`), daily snapshots (`kft_app_kv_snapshots`), shrink guard (>20% blocked), and restore test script (`userDataRestoreTest.mjs`). Warning: local disk backups are unencrypted plaintext JSON.
9	**Compliance with Cambodian Cybersecurity & Data Protection Laws**	**FAIL**	**40/100**	Meets E-Commerce consumer transparency, KHQR audit logging, and consent/deletion rules, but fails **E-Commerce Law Art. 32** & **Sub-Decree No. 252** due to unauthenticated access to personal data in `kft_app_kv_store`.

2. Domain-by-Domain Technical Audit & Code Verification

Domain 1: Anti-Hacking & Unauthorized Access Protection

STATUS: FAIL

Verified Protections in Code

- **Native Package & Signature Inspection:** `NativeAppIntegrityPlugin.java:19-64` and `src/utils/appCloneIntegrityGuard.ts:1-228` inspect package name (`com.khmerfood.tourism`), APK signing SHA-256 (`09d17b38...`), and installer package (`com.android.vending`).
- **Edge & DB Clone Triggers:** `verifyClientAppIntegrity()` in `supabase/functions/_shared/common.ts:172-181` and trigger `e_kft_clone_guard` in `supabase_anti_clone_rls_v1.sql:179-228` reject requests carrying `x-kft-app-sig: TAMPERED_CLONE`.
- **Burst & Daily Rate Limiting:** `WindowLimiter` in all Edge Functions + Postgres daily counters in `public.kft_api_usage_daily`.

Verified Weaknesses & Missing Protections

- **[CRITICAL] Unauthenticated Access to `kft_app_kv_store`:** Policy `Allow public read and write for app sync` (`supabaseService.ts:1218-1222`) grants `anon` unrestricted `SELECT`, `INSERT`, and `UPDATE`.
- **[CRITICAL] Exposed Signing Keystore:** `android/app/khmerfood-upload-key.jks` and fallback password `KhmerFood2026PlayStore` in `android/app/build.gradle:28-35` and `.github/workflows/build-apk.yml:165` are committed to Git.
- **[HIGH] Spoofable Attestation Headers:** `verifyClientAppIntegrity()` checks plain HTTP headers without Google Play Integrity API cryptographic verdict tokens.
- **[MEDIUM] ProGuard Keep Rule:** `proguard-rules.pro:9` keeps `com.khmerfood.tourism.**` unobfuscated.

Domain 2: Login, Authentication, Passwords & Account Security

STATUS: FAIL

Verified Protections in Code

- **NIST SP 800-132 Password Hashing:** `src/utils/security.ts:31-65` implements `PBKDF2-HMAC-SHA256` with 100,000 iterations and a 32-byte random salt.
- **Constant-Time Verification:** `timingSafeEqual()` in `src/utils/security.ts:70-79` prevents timing side-channel leaks.
- **Identity Field Immutability Guard:** `kft_kv_guard()` in `supabase_security_hardening_v2.sql:106-123` blocks overwriting an existing non-empty `email`, `googleSub`, or `phone` on `kft_user_*` rows.
- **Hardware Biometric Support:** `NativeBiometricAuthPlugin.java` integrates AndroidX `BiometricPrompt`.

Verified Weaknesses & Missing Protections

- **[CRITICAL] Client-Side Password Verification:** User login in `src/context/AppContext.tsx:8541-8555` downloads user records to the client and verifies passwords locally instead of issuing a server-side session JWT.
- **[CRITICAL] Publicly Readable `passwordHash` & `x-kft-prev-pw-hash` Bypass:** Anyone can `SELECT` a user's `passwordHash` from `kft_app_kv_store` and send that hash in the `x-kft-prev-pw-hash` header (`supabase_security_hardening_v2.sql:41,124-129`) to overwrite the victim's password, or set a password on Google-only accounts where `passwordHash` is empty.
- **[HIGH] Self-Asserted `x-kft-user-id` Header:** Edge Functions accept `x-kft-user-id` without verifying a user JWT, allowing impersonation of known VIP `userId` values.

Domain 3: Database, API & Server Security

STATUS: FAIL

Verified Protections in Code

- **8 Locked-Down Internal Tables:** `kft_security_config`, `kft_payment_receipts`, `kft_used_aba_transactions`, `kft_payment_audit_log`, `kft_trial_promo_claims`, `kft_api_usage_daily`, `kft_api_cache`, and `kft_security_events` enforce RLS with `REVOKE ALL FROM anon, authenticated`.
- **Server-Only API Keys:** `GEMINI_API_KEY`, `OPENAI_API_KEY`, and `GOOGLE_MAPS_API_KEY` are kept in Supabase Edge secrets; 0 secrets exist in `dist/`.
- **Hardened Storage Bucket:** `supabase_security_hardening_v2.sql:168-197` blocks anonymous `UPDATE` / `DELETE` on `food-media`.

Verified Weaknesses & Missing Protections

- **[CRITICAL] Monolithic Key-Value Table Design:** `public.kft_app_kv_store` stores public catalog items alongside private user accounts, payment proofs, and support tickets with table-wide `SELECT USING (true)`.
- **[MEDIUM] Wildcard CORS Headers:** Edge Functions set `Access-Control-Allow-Origin: *` instead of restricting to official web/Capacitor origins.
- **[LOW] Unused Legacy Rule Files:** `firestore.rules` and `storage.rules` in repo root are unused by Supabase.

Domain 4: VIP Membership & Payment Protection

STATUS: WARNING

Verified Protections in Code

- **PostgreSQL VIP Grant Guard (`d_kft_vip_grant_guard`):** `supabase_anti_clone_rls_v1.sql:40-176` automatically strips forged `membershipTier='premium_vip'` , expiry extensions, and store-slot escalations unless signed by Admin token or `service_role` .
- **Global ABA Transaction & Receipt Hash Ledger:** `kft_used_aba_transactions` and `kft_payment_receipts` (`supabase_aba_vip_verification_v1.sql:9-65`) enforce unique constraints on normalized ABA `trx_key` and receipt `image_hash` .
- **Server-Enforced Pricing:** `vip-purchase/index.ts:118-175` enforces official pricing ($1.99 promo, $3.99/30d, $7.99/90d, $19.99/365d).
- **1-Time Trial Ledger:** `kft_trial_promo_claims` blocks duplicate 7-day trials by user, email/phone hash, and device hash.

Verified Weaknesses & Missing Protections

- **[HIGH] Payment Proofs & Transaction Arrays in Public KV Store:** While `kft_payment_receipts` is private, client sync also writes `kft_cloud_transactions_v1` and `kft_cloud_payment_proofs_v1` to `kft_app_kv_store` (`supabaseService.ts:1055-1155`), making uploaded receipt images and ABA reference numbers readable by `anon` .
- **[MEDIUM] Client-Side `integritySeal` :** `src/utils/crypto.ts` computes `integritySeal` with a static salt in client JS (mitigated on server by `kft_vip_grant_guard`).
- **[MEDIUM] No Direct ABA PayWay Webhook:** Relies on AI receipt forensics + Admin bank statement matching rather than direct bank webhook callbacks.

Domain 5: Personal Data & Privacy Protection

STATUS: FAIL

Verified Protections in Code

- **Explicit AI Data-Sharing Consent:** `src/services/aiConsent.ts:1-45` requires opt-in user permission before sending queries or photos to Gemini/OpenAI, with one-tap revocation.
- **Self-Service Permanent Account Deletion:** `src/components/PrivacyPolicyModal.tsx:18-30` permanently deletes the user's account and associated data.
- **Android Backup Disabled:** `AndroidManifest.xml:12` sets `android:allowBackup="false"`.
- **Local AES-GCM-256 Helper:** `src/utils/security.ts:225-295` provides WebCrypto `AES-GCM-256` encryption for local session storage.

Verified Weaknesses & Missing Protections

- **[CRITICAL] Unauthenticated PII Exposure in Cloud DB:** `kft_user_*`, `kft_cloud_users_v2`, `kft_cloud_support_tickets_v1`, and `kft_cloud_activity_logs_v1` in `kft_app_kv_store` expose user emails, phone numbers, and Google sub IDs to unauthenticated REST queries.
- **[CRITICAL] Historical Backup Files in Git:** `backup/database_backup_before_user_purge_2026-10-23.json` and `_backups/` contain PII and are tracked in version control.

Domain 6: Malware, SQL Injection, Data Theft & Cyberattack Prevention

STATUS: WARNING

Verified Protections in Code

- **SQL Injection Prevention (PASS):** 100% of queries use PostgREST parameterized filters or typed `plpgsql` variables. Zero dynamic SQL string concatenation with user input.
- **XSS Prevention (PASS):** Zero `dangerouslySetInnerHTML`, `eval()`, or `new Function()` across all 181 files in `src/`; `sanitizeInput()` strips script tags and event handlers.
- **Magic-Byte Image Validation:** `validateImageUpload()` (`src/utils/security.ts:300-348`) verifies binary file signatures (JPEG `FF D8 FF`, PNG `89 50 4E 47`, WebP `52 49 46 46`) and 5 MB size cap.
- **HTTPS Enforcement:** `network_security_config.xml:4` blocks cleartext HTTP traffic (`cleartextTrafficPermitted="false"`).

Verified Weaknesses & Missing Protections

- **[HIGH] Unauthenticated Bulk Database Scraping:** Because `kft_app_kv_store` allows public `SELECT`, an external script can dump all rows in a single call.
- **[MEDIUM] Empty Certificate Pinning Set:** `network_security_config.xml:18-20` defines an empty `<pin-set>` with no SHA-256 SPKI pins.
- **[MEDIUM] Missing Web Security Headers:** No `vercel.json` or response header policy defines `Content-Security-Policy`, `Strict-Transport-Security`, or `X-Frame-Options: DENY`.

Domain 7: Admin Access Control & Permission Management

STATUS: WARNING

Verified Protections in Code

- **2-Step Server-Side Admin Auth (`admin-auth`):** `supabase/functions/admin-auth/index.ts:1-320` requires a 6-digit PIN (issuing a 10-min HMAC ticket) followed by Admin username + password (issuing a signed HMAC-SHA256 admin token).
- **Database Trigger Enforcement:** `kft_admin_keys_guard()` (`supabase_admin_security_v1.sql:97-143`) and `kft_kv_guard()` verify `public.kft_admin_token_ok(x-kft-admin-token)` before allowing edits to app settings, VIP pricing, admin PIN, or destructive deletes.
- **Role Escalation Blocked:** `supabase_security_hardening_v2.sql:93-103` prevents unauthenticated callers from setting `role` to `admin` or `owner` on `kft_user_*` rows.

Verified Weaknesses & Missing Protections

- **[MEDIUM] Global Admin Lockout DoS:** `admin-auth/index.ts:121-125` locks out ALL admin logins globally when `globalFails >= 200` (or `ipFails >= 8` on shared mobile carrier IPs), allowing an attacker to intentionally lock out the legitimate Admin.
- **[MEDIUM] Client UI Fallback on Network Failure:** `adminAuthClient.ts:78-130` returns `kind: 'unavailable'` if the Edge Function cannot be reached, which allows local UI fallback (though DB triggers still block unauthorized server writes).
- **[MEDIUM] 7-Day Token TTL:** `TOKEN_TTL_S = 7 * 24 * 3600` is overly long for an administrative session without a per-token revocation table.

Domain 8: Backup, Recovery & Data Protection

STATUS: WARNING

Verified Protections in Code

- **Append-Only Audit History & Daily Snapshots:** `supabase_user_data_safety_v1.sql:25-185` maintains `public.kft_app_kv_history` on every write and `public.kft_app_kv_snapshots` daily, plus `kft_restore_missing_users_from_snapshot()` .
- **Anti-Shrink Guard:** `kft_kv_guard()` blocks `kft_cloud_users_v2` from shrinking by ≥20% in a single write without a verified Admin token.
- **Verified Offline Backup & Restore Drills:** `scripts/userDataBackup.mjs` creates SHA-256 verified backups and `scripts/userDataRestoreTest.mjs` tests total-loss and partial-loss recovery.

Verified Weaknesses & Missing Protections

- **[MEDIUM] Unencrypted Plaintext Disk Backups:** Local backup files under `backups/users/` and `backup/` are stored as unencrypted JSON on the workstation disk.
- **[LOW] Backup Script Auth Key:** `scripts/userDataBackup.mjs` should be configured to use `SUPABASE_SERVICE_ROLE_KEY` from an external secret vault once `anon` read access on `kft_app_kv_store` is revoked.

Domain 9: Compliance with Applicable Cambodian Cybersecurity & Data Protection Laws

STATUS: FAIL

Verified Legal Compliance Strengths

- **E-Commerce Law (2019) Arts. 18–24 (Consumer Transparency):** Clear trilingual VIP pricing, explicit plan durations (30d/90d/365d), no hidden auto-renewals, and official merchant details.
- **Sub-Decree No. 252 & App Store Privacy (Consent & Deletion):** Explicit AI consent (`aiConsent.ts`), trilingual privacy policy, and permanent self-service account deletion (`PrivacyPolicyModal.tsx`).
- **NBC KHQR & Payment Auditability:** Centralized immutable payment audit trail (`kft_payment_audit_log` and `kft_used_aba_transactions`).

Compliance Gaps Requiring Immediate Remediation

- **[CRITICAL — Cambodian E-Commerce Law Art. 32 & Sub-Decree No. 252]:** Article 32 mandates that electronic service providers protect personal data stored in electronic systems against unauthorized access or disclosure. Public `anon` read access on `kft_app_kv_store` exposes user emails, phone numbers, and payment references without authentication.
- **[HIGH — Data Minimization in Version Control]:** Historical JSON backups containing real user PII in `backup/` must be purged from Git history.

3. Prioritized Vulnerability Register & Risk Matrix

ID	Severity	Vulnerability / Weakness	Verified Location (File & Lines)	Exploit Impact & Required Fix
C-01	CRITICAL	**Public `anon` Read/Write RLS Policy on `kft_app_kv_store`**	`src/services/supabaseService.ts:1218-1222` Live table `public.kft_app_kv_store`	**Impact:** Anyone with the bundled publishable key can dump all `kft_user_*`, `kft_cloud_users_v2`, `kft_cloud_transactions_v1`, and `kft_cloud_payment_proofs_v1` rows. **Fix:** Split private records into dedicated RLS-protected tables or restrict `kft_app_kv_store` `SELECT` to public catalog keys only and route user/transaction reads & writes through authenticated Edge Functions.
C-02	CRITICAL	**Client-Side User Auth & `x-kft-prev-pw-hash` Password Overwrite Bypass**	`src/context/AppContext.tsx:8541-8555` `supabase_security_hardening_v2.sql:41, 124-129`	**Impact:** An attacker can read a victim's `passwordHash` from `kft_app_kv_store` and send it in `x-kft-prev-pw-hash` to overwrite the victim's password (or set a password on Google-only accounts), achieving Account Takeover. **Fix:** Migrate user authentication to `Supabase Auth` (or a server-side `user-auth` Edge Function) and never expose `passwordHash` to client `SELECT` queries.
C-03	CRITICAL	**Android Release Keystore & Fallback Password Committed to Repository**	`android/app/khmerfood-upload-key.jks` `android/app/build.gradle:28-35, 48-51` `.github/workflows/build-apk.yml:163-166`	**Impact:** Anyone with repository access can extract the signing key and sign trojanized APKs with the identical certificate SHA-256. **Fix:** Make the GitHub repo private, remove `*.jks` and fallback passwords from Git history, rotate the upload key in Google Play Console, and inject signing credentials exclusively via CI Secrets.
C-04	CRITICAL	**Historical User PII Backups Committed to Git**	`backup/database_backup_before_user_purge_2026-10-23.json` `_backups/`	**Impact:** Exposes real owner/user email addresses and phone numbers in repository history. **Fix:** Add `backup/` and `_backups/` to `.gitignore` and purge from Git history using `git filter-repo`.
H-01	HIGH	**Self-Asserted `x-kft-user-id`**	`supabase/functions/food-ai/index.ts:177` `supabase/functions/places-proxy/index.ts:59`	**Impact:** Attackers who know a valid VIP user ID can pass it in

ID	Severity	Vulnerability / Weakness	Verified Location (File & Lines)	Exploit Impact & Required Fix
		Header on Edge Functions	`supabase/functions/vip-purchase/index.ts:314`	`x-kft-user-id` to consume that VIP user's daily AI quota (80/day). **Fix:** Issue an HMAC-signed session token (or Supabase Auth JWT) upon login and extract `userId` from the verified token on the server.
H-02	**HIGH**	**Payment Proofs & Transaction Summaries Readable in `kft_app_kv_store`**	`src/services/supabaseService.ts:1055-1155`	**Impact:** `kft_cloud_transactions_v1` and `kft_cloud_payment_proofs_v1` are stored in the publicly readable KV store, exposing user payment receipts. **Fix:** Restrict read access on those two keys to verified Admin tokens (`kft_admin_token_ok`) or move them to a service-role table.
H-03	**HIGH**	**Spoofable Client App Attestation Headers (No Play Integrity Verdict)**	`supabase/functions/_shared/common.ts:172-181` `supabase_anti_clone_rls_v1.sql:179-228`	**Impact:** Repackaged scripts/clones can send `x-kft-app-id: com.khmerfood.tourism` to bypass `verifyClientAppIntegrity()` . **Fix:** Integrate Google Play Integrity API on Android and verify the signed integrity token server-side in Edge Functions.
M-01	**MEDIUM**	**Global Admin Lockout Counter Allows DoS Against Legitimate Admin**	`supabase/functions/admin-auth/index.ts:121-125`	**Impact:** 200 failed PIN attempts globally in a day locks out the real Admin across all IPs (`429 LOCKED`). **Fix:** Key lockouts by `(ip, device_fingerprint)` with exponential backoff instead of a global hard lockout.
M-02	**MEDIUM**	**Admin Client UI Fallback & 7-Day Admin Token Lifetime**	`src/services/adminAuthClient.ts:78-130` `supabase/functions/admin-auth/index.ts:32`	**Impact:** Network interception returning 503 triggers `'unavailable'` fallback; 7-day token has no per-token revocation. **Fix:** Enforce fail-closed server verification and shorten Admin token TTL to 4–8 hours.
M-03	**MEDIUM**	**Empty TLS `<pin-set>` , ProGuard Keep Rule & Missing Web CSP/HSTS**	`network_security_config.xml:18-20` `proguard-rules.pro:9`	**Impact:** No active SPKI certificate pinning; custom Java plugins unobfuscated; web build lacks CSP/HSTS headers. **Fix:** Narrow ProGuard `-keep` to `@PluginMethod` methods, add SPKI pins or remove empty

ID	Severity	Vulnerability / Weakness	Verified Location (File & Lines)	Exploit Impact & Required Fix
				`<pin-set>`, and add `vercel.json` security headers.

4. Practical Step-by-Step Remediation Roadmap

Phase 1 — Immediate Critical Fixes (24–48 Hours)

1. **Lock Down Sensitive Keys in `public.kft_app_kv_store` RLS (Fixes C-01, H-02, Domain 9):** Replace the permissive `SELECT USING (true)` policy on `public.kft_app_kv_store` with a scoped `SELECT` policy that allows anonymous/public reads ONLY on public catalog keys (`kft_ov_food_*`, `kft_cloud_media_overrides_v1`, `kft_cloud_custom_restaurants_v1`, `kft_cloud_deleted_restaurants_v1`, `kft_cloud_app_settings_v1`, `kft_cloud_admin_vip_pricing_v2`), while requiring a signed Admin token (`public.kft_admin_token_ok(...)`) or `service_role` to read `kft_cloud_users_v2`, `kft_cloud_transactions_v1`, `kft_cloud_payment_proofs_v1`, `kft_cloud_support_tickets_v1`, and `kft_cloud_activity_logs_v1`.
2. **Move User Login & Password Verification Server-Side (Fixes C-02, H-01):** Strip `passwordHash` from any client-readable payload and verify user logins inside a dedicated Edge Function (or `Supabase Auth`) that returns a signed user session token (`x-kft-user-token`). Require this signed token for `food-ai`, `vip-purchase`, and profile updates instead of trusting raw `x-kft-user-id` or `x-kft-prev-pw-hash` headers.
3. **Secure Repository & Rotate Android Upload Keystore (Fixes C-03, C-04):** Set the GitHub repository to **Private**, remove `android/app/khmerfood-upload-key.jks`, `PlayStore-Assets/khmerfood-upload-key.jks`, `backup/`, and `_backups/` from Git tracking and history (`git filter-repo`), remove the hardcoded fallback password `KhmerFood2026PlayStore` from `android/app/build.gradle` and `.github/workflows/build-apk.yml`, and request an Upload Key Reset in Google Play Console.

Phase 2 — High-Priority Server & Admin Hardening (Week 1)

4. **Fix Global Admin Lockout DoS & Shorten Admin Token TTL (Fixes M-01, M-02):** In `supabase/functions/admin-auth/index.ts`, remove the global 200-attempt lockout threshold (which lets attackers lock out the legitimate Admin) and replace it with per-IP + exponential backoff rate limiting. Reduce `TOKEN_TTL_S` from 7 days to 8 hours and remove any client-side offline fallback in `AdminLoginModal.tsx`.
5. **Encrypt Local User Backups at Rest (Fixes Domain 8 Warning):** Update `scripts/userDataBackup.mjs` to authenticate with `SUPABASE_SERVICE_ROLE_KEY` and encrypt exported JSON files using `AES-256-GCM` (Node `crypto.createCipheriv('aes-256-gcm', ...)`) before writing to disk.

Phase 3 — Defense-in-Depth & Mobile Hardening (Week 2)

6. **Integrate Google Play Integrity API & Tighten ProGuard (Fixes H-03, M-03):** Request a hardware-backed Play Integrity token on Android before high-value actions (trial claim, VIP purchase, AI chat) and verify it in Supabase Edge Functions. Update `android/app/proguard-rules.pro` to keep only `@CapacitorPlugin` and `@PluginMethod` annotations rather than `-keep class com.khmerfood.tourism.** { *; }`.
7. **Add Web HTTP Security Headers (`vercel.json`):** Add `Strict-Transport-Security`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: strict-origin-when-cross-origin`, and a strict `Content-Security-Policy`.